

SYSTEM DESIGN DOCUMENT

DDoS Prevention & Mitigation Platform

A defense-in-depth architecture protecting enterprise cloud infrastructure against volumetric, protocol, and application-layer denial-of-service attacks through edge absorption, traffic scrubbing, adaptive rate limiting, and ML-driven anomaly detection.

AUDIENCE Architecture review	SCOPE L3 / L4 / L7	TARGET Cloud-agnostic	AVAILABILITY SLO 99.99%
---------------------------------	-----------------------	--------------------------	----------------------------

CONTENTS

- 01 Problem & Objectives

02 Requirements & SLAs

03 Threat Model

04 High-Level Architecture

05 Request Lifecycle
- 06 Component Deep-Dives

07 Monitoring & Ops Dashboard

08 Incident Response Runbook

09 Capacity, Scaling & Tradeoffs

10 Failure Modes & Cloud Mapping

SECTION 01

Problem & Objectives

Distributed Denial-of-Service attacks aim to exhaust a target's finite resources — bandwidth, connection tables, CPU, or downstream dependencies — until legitimate users can no longer be served. Modern attacks are cheap to launch, increasingly automated, and span every layer of the stack simultaneously: a single campaign may pair a multi-terabit UDP flood with a low-and-slow HTTP request flood designed to slip past volumetric defenses.

This system is designed to keep customer-facing services available and performant throughout an attack, degrading gracefully rather than failing, while remaining transparent to legitimate traffic. The controlling principle is **defense in depth**: no single layer is trusted to stop everything; each layer removes a class of malicious traffic so the layer behind it faces a smaller, cleaner problem.

GOAL 1

Absorb & disperse

Soak up volumetric floods far from the origin using globally distributed edge capacity.

GOAL 2

Distinguish intent

Separate humans from bots and legitimate spikes from attacks with high precision, low false positives.

GOAL 3

React automatically

Detect, decide, and mitigate in seconds without a human in the critical loop.

SECTION 02

Requirements & SLAs

Functional requirements

- Inspect and filter traffic at L3/L4 (packet/flow) and L7 (request) before it reaches origin.
- Apply per-client, per-endpoint, and global rate limits with configurable actions (throttle, challenge, block).
- Detect anomalies against learned baselines and auto-escalate mitigation posture.
- Allow security operators to observe, override, and roll back mitigations in real time.
- Preserve legitimate traffic — mitigations must be reversible and scoped as narrowly as possible.

Non-functional targets

METRIC	TARGET	RATIONALE
Availability (SLO)	99.99% / yr	≈52 min error budget; sustained through active attack.
Time to detect (TTD)	< 10 s	From attack onset to anomaly signal at the policy engine.
Time to mitigate (TTM)	< 30 s	Auto-mitigation rule pushed to edge and enforced globally.
Added p99 latency	< 5 ms	Edge inspection overhead on clean requests.
False-positive rate	< 0.1%	Legitimate users wrongly challenged/blocked.
Absorption capacity	multi-Tbps	Aggregate edge headroom > largest observed floods.

SECTION 03

Threat Model

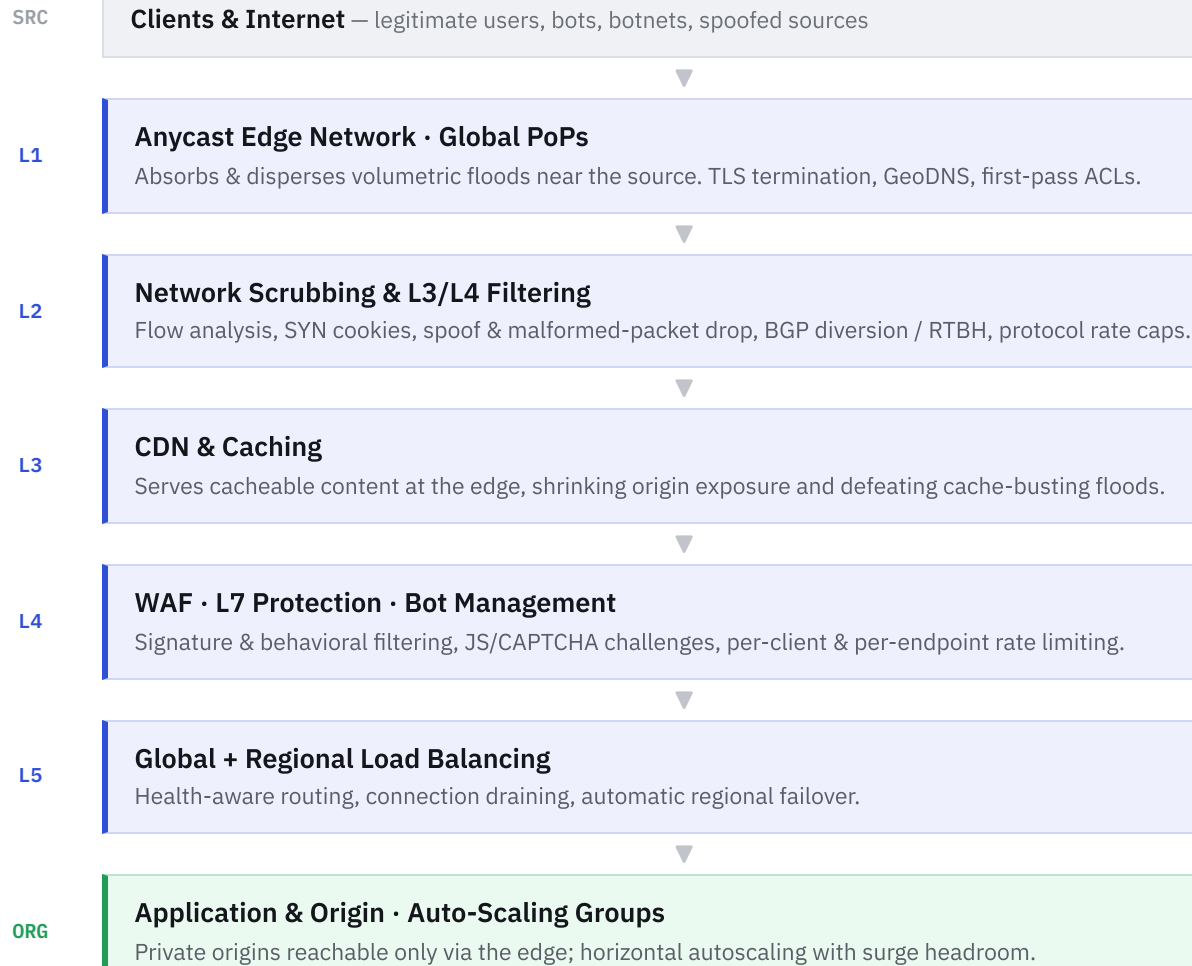
Attacks are grouped by the layer they target. Each class has a distinct signature and a distinct primary defense; the architecture assigns every class to the layer best positioned to neutralize it.

CLASS	EXAMPLES	SIGNATURE	PRIMARY DEFENSE
Volumetric L3/L4	UDP / ICMP flood, DNS & NTP amplification, reflection	Massive bandwidth & PPS from spoofed sources	Anycast dispersion + scrubbing + BGP
Protocol L3/L4	SYN flood, ACK flood, fragmentation, Ping of Death	Exhausts connection tables / firewall state	SYN cookies, stateless filtering
Application L7	HTTP(S) flood, cache-busting, Slowloris, expensive queries	Looks like real requests; low volume, high cost	WAF, rate limiting, challenges, bot mgmt
Multi-vector	Simultaneous L3/4 + L7, shifting vectors	Diversionary; probes for gaps	Coordinated posture across all layers

SECTION 04

High-Level Architecture

Traffic flows top-to-bottom through progressively finer filters (the **data plane**). A separate **control plane** observes telemetry from every layer, detects anomalies, and pushes mitigation policy back down — a closed feedback loop that tightens defenses automatically as an attack develops.



CONTROL PLANE · CLOSED FEEDBACK LOOP



~ enforced rules feed new telemetry — loop closes in < 30 s ~

Fig 1 — Layered data plane (L1–L6) with the control-plane feedback loop that drives automatic mitigation.

SECTION 05

Request Lifecycle

The path of a single request, and the decision points where malicious traffic is dropped, challenged, or throttled before it can consume origin resources.

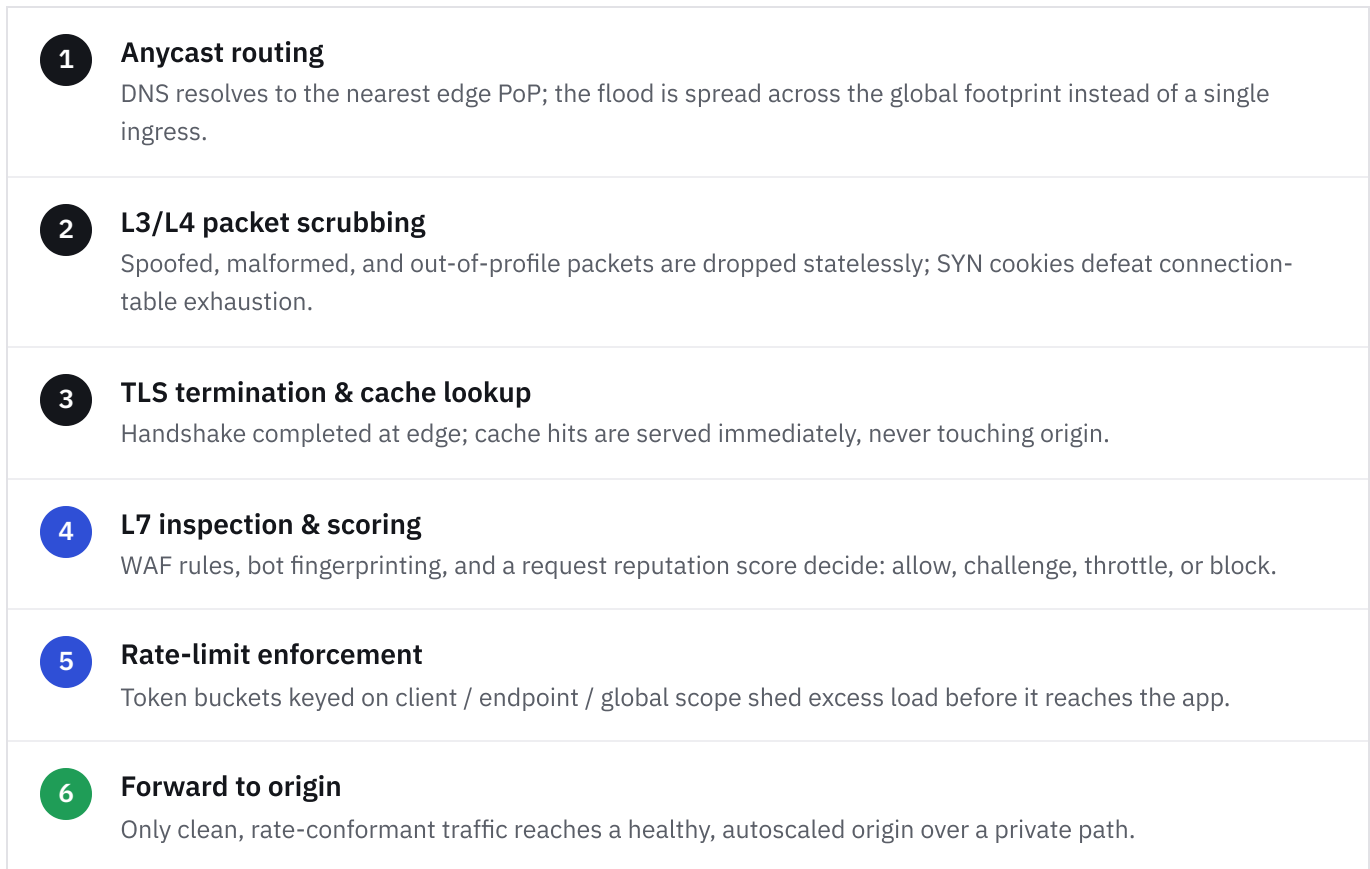


Fig 2 — Request lifecycle. Every telemetry point along this path streams to the control-plane bus (Fig 1).

SECTION 06

Component Deep-Dives

L1 Anycast Edge & CDN

The same IP prefixes are announced from dozens of geographically distributed PoPs. A volumetric flood is therefore split across the entire footprint — a 2 Tbps attack fragmenting into manageable fractions per PoP — while each user is routed to the topologically nearest one. Caching at the edge means most legitimate content is served without ever reaching origin, and TLS is terminated close to the user for latency.

Key mechanisms: BGP anycast · GeoDNS · edge TLS · tiered caching · origin shielding

L2 Traffic Filtering & Scrubbing

Scrubbing centers perform line-rate flow analysis. Benign traffic passes through; suspicious flows are diverted for deep inspection. Stateless filters drop spoofed source addresses (uRPF), malformed/fragmented packets, and known reflection/amplification signatures (DNS, NTP, memcached). SYN cookies answer handshakes without allocating state, neutralizing SYN floods. When volume exceeds local capacity, **BGP diversion** reroutes the prefix through additional scrubbing capacity, with remotely-triggered blackhole (RTBH) as a last resort for a single sacrificial target.

Key mechanisms: flow sampling (sFlow/NetFlow) · uRPF · SYN cookies · ACL/BPF drop · BGP diversion · RTBH

L4 Rate Limiting

Rate limiting is enforced at the edge using distributed **token buckets**, evaluated at multiple scopes so a single abusive client can be throttled without affecting others, while a global ceiling protects shared capacity. Limits are adaptive: baselines tighten automatically when the control plane raises the mitigation posture.

PER-CLIENT

Keyed on IP / ASN / token / fingerprint. Stops single-source floods.

PER-ENDPOINT

Protects expensive routes (login, search, checkout) with stricter caps.

GLOBAL

Hard ceiling on aggregate throughput to guarantee origin headroom.

Actions escalate: throttle → JS challenge → CAPTCHA → temporary block. Sliding-window counters + token bucket; state shared via edge KV.

CP Anomaly Detection & ML

The control plane learns a rolling baseline of normal behavior per service — request rates, geo/ASN mix, method & path distributions, cache-hit ratio, error rates, and TLS/JA3 fingerprints — accounting for seasonality (daily and weekly cycles). A layered detector combines fast statistical triggers with heavier models:

- **Statistical (seconds):** EWMA / z-score / entropy on traffic distributions catch sudden volumetric and distributional shifts.
- **Unsupervised (near-real-time):** clustering & isolation forests flag coordinated bot behavior that no single-signal rule would.
- **Supervised classifier:** a bot-vs-human model scores requests on features that are expensive to forge, feeding the L7 decision.

Output: an anomaly score + suggested mitigation, handed to the policy engine. Human-in-the-loop review of flagged mitigations feeds back as labeled training data.

L4 Application-Layer (L7) Protection

Because L7 floods mimic real users, defense is behavioral, not just signature-based. A managed WAF ruleset blocks known exploit patterns; bot management fingerprints clients (TLS/JA3, HTTP/2 behavior, header order) and issues progressive challenges — invisible JS proof-of-work first, interactive CAPTCHA only when the score warrants it, minimizing friction for real users. Slowloris and slow-POST attacks are countered with connection and header/body timeouts at the edge.

Key mechanisms: managed + custom WAF rules · JA3/behavioral bot scoring · progressive challenges · timeouts · reputation lists

L5 Auto-Scaling & Failover

Origins run in autoscaling groups across multiple availability zones with pre-warmed surge headroom, so that traffic passing all upstream filters still cannot overwhelm capacity. Health checks eject unhealthy instances; global load balancing performs regional failover if an entire region degrades. Scaling policy is coupled to the mitigation posture — the system prefers to *shed and challenge* attack traffic at the edge over scaling origin to serve it, avoiding a cost-amplification (“economic”) DoS.

Key mechanisms: multi-AZ ASGs · pre-warmed headroom · health-aware LB · regional failover · graceful degradation modes

SECTION 07

Monitoring & Ops Dashboard

The SOC operates from a single real-time view: live traffic, current mitigation posture, attack composition, and an actionable alert feed. Below is the target layout of the operator console.



Fig 3 — Operator console during an active multi-vector attack. Values illustrative.

SECTION 08

Incident Response Runbook

Most mitigation is automatic. This runbook covers the human loop — escalation, judgment calls, and communication — when an incident exceeds automated handling or requires override.

PHASE 1

Detect

0-10 s · auto

Anomaly detector crosses threshold; alert opened, severity assigned, on-call paged. Baseline snapshot and attack fingerprint captured automatically.

PHASE 2**Auto-mitigate**

10-30 s · auto

Policy engine selects and pushes scoped mitigations (rate caps, challenges, filters, BGP diversion). Posture raised to **Defensive**. Operator observes; no action required unless mitigation is ineffective.

PHASE 3**Escalate**

human loop

If SLOs degrade despite auto-mitigation: incident commander engaged, war room opened, upstream provider / transit scrubbing notified. Operator may apply manual filters, tighten global caps, or enable emergency “I’m under attack” mode (challenge all).

PHASE 4**Recover**

wind-down

As the attack subsides, mitigations are relaxed gradually (not all at once) to confirm the attack has ended and avoid re-triggering. Posture returns to **Normal**; SLOs verified restored.

PHASE 5**Learn**

post-incident

Blameless post-mortem; attack signature and operator decisions become labeled training data; detection thresholds and rules are tuned to shorten the next response.

SECTION 09

Capacity, Scaling & Tradeoffs

Scaling principles

- Absorb where capacity is cheapest — the distributed edge, not origin.
- Total edge headroom must exceed the largest plausible flood with margin.
- Prefer shedding malicious load over scaling to serve it (avoids economic DoS).
- Detection/decision state is regional & replicated so no single controller is a bottleneck or SPOF.

Key tradeoffs

- **Security vs. friction:** aggressive challenges block bots but annoy users — resolved via progressive, score-driven challenges.
- **Sensitivity vs. false positives:** tighter detection reacts faster but risks blocking real spikes — tuned per-service with human review.
- **Latency vs. inspection depth:** deeper L7 analysis costs milliseconds — kept within the <5ms budget by scoping deep inspection to suspicious flows.

SECTION 10

Failure Modes & Cloud Mapping

Failure modes & safeguards

FAILURE MODE	SAFEGUARD
Detector false positive blocks real users	Scoped & reversible mitigations, progressive challenges, fast human override & rollback.
Control plane unavailable	Edge fails to last-known-good ruleset; enforcement is local and continues without the controller.
Attack exceeds edge capacity	BGP diversion to upstream/transit scrubbing; RTBH for a single sacrificial target as last resort.
Origin IP exposed / direct-to-origin	Origins on private networks; allowlist only edge egress; rotate origin addresses.
Economic (cost) DoS via autoscaling	Scaling caps + prefer edge shedding; budget alarms; posture-coupled scaling policy.

Cloud-agnostic component mapping

CAPABILITY	AWS	GCP	AZURE
Edge / CDN / WAF	CloudFront + WAF	Cloud CDN + Armor	Front Door + WAF
L3/4 DDoS protection	Shield Advanced	Cloud Armor	DDoS Protection
Global load balancing	Route 53 + ALB/NLB	Global LB	Traffic Manager + LB
Autoscaling compute	ASG / EKS	MIG / GKE	VMSS / AKS
Telemetry & alerting	CloudWatch / Kinesis	Cloud Monitoring	Monitor / Event Hubs

End of document · DDoS Prevention & Mitigation Platform — System Design, Rev 1.0. Managed-service names are illustrative mappings of the reference architecture, not an endorsement.